COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.8 · Digital Forensics

Mestre CyberSec · **Aula 4.8 — Digital Forensics** (9:54) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Forense: data collection (VOLÁTIL primeiro — RAM→cache→disco→backup); legal hold (preserva evidência — notifica o jurídico); chain of custody (quem tocou/ quando — sem isso a evidência não vale em tribunal).

💡 Highlights que a prova CompTIA cobra

- Ordem de volatilidade: RAM primeiro (perde ao desligar)
- Chain of custody: o registro formal de cada ação com a evidência

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'documenting who handled the evidence'=chain of custody

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.8 — Digital Forensics)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Ordem de Volatilidade (OoV)

A sequência obrigatória para coleta de evidência digital baseada na rapidez com que os dados se degradam ou desaparecem, começando pela fonte mais volátil.

⚠️ ***Armadilha CompTIA:*** *Lembre-se da ordem: RAM/CPU → cache/registradores → disco rígido → logs remotos → backups. Examinadores esperam a ordem RAM primeiro porque perde ao desligar.*

• Cadeia de Custódia (N/A)

O registro formal e documentado de cada pessoa que manipulou uma evidência digital, o horário da transferência e as ações realizadas em cada etapa.

⚠️ ***Armadilha CompTIA:*** *Gatilho clássico: 'documenting who handled the evidence' = Chain of Custody. Sem ela, a evidência é inadmissível em tribunal.*

• Suspensão Legal / Preservação Legal (N/A)

A diretiva do jurídico para preservar todos os dados relevantes e suspender a destruição rotineira quando litígio é razoavelmente esperado.

⚠️ ***Armadilha CompTIA:*** *Legal Hold é emitida ANTES da coleta efetiva de evidência — notifica TI para parar de deletar dados (e-mails, logs). Não confundir com o processo de coleta em si.*

• Imagem Forense (Cópia Bit-a-Bit) (N/A)

Uma réplica exata, setor por setor, de um dispositivo de armazenamento, incluindo arquivos deletados e slack space, verificada por hash criptográfico.

⚠️ ***Armadilha CompTIA:*** *NUNCA trabalhe diretamente no disco original — sempre crie uma imagem forense. Se o exame mencionar 'working with original evidence', é resposta errada.*

• Descoberta Eletrônica (eDiscovery)

O processo de identificar, coletar e produzir informações armazenadas eletronicamente (ESI) em resposta a uma solicitação legal ou investigação.

⚠️ ***Armadilha CompTIA:*** *eDiscovery é o processo corporativo/legal; Forensic é o técnico de campo. Legal Hold dispara o eDiscovery — pense em fluxo: Legal Hold → eDiscovery → Forensics.*

• Aquisição de Dados (N/A)

O processo de extrair e preservar dados de fontes voláteis (RAM) e não-voláteis (disco) durante uma investigação forense.

⚠️ ***Armadilha CompTIA:*** *Siga a ordem de volatilidade na prova: se a pergunta listar ações de aquisição, a ordem correta SEMPRE começa pela RAM.*

• Verificação de Integridade (Hash Criptográfico) (N/A)

Uso de algoritmos como MD5 ou SHA-256 para gerar um hash único da evidência antes e depois da aquisição, provando que não houve adulteração.

⚠️ ***Armadilha CompTIA:*** *Hashes provam integridade — devem ser idênticos antes e depois. Se o hash mudar, a evidência foi comprometida. Use SHA-256 (não MD5) por padrão moderno.*

• Cláusula de Direito de Auditoria (N/A)

Disposição contratual que concede a uma organização o direito legal de auditar registros e processos de um fornecedor terceirizado para conformidade.

⚠️ ***Armadilha CompTIA:*** *Relacionado a evidências de terceiros: aparece em questões sobre fornecedores cloud/SaaS. Sem esta cláusula, você pode não ter acesso à evidência do provedor.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um respondente de incidentes chega a uma estação de trabalho comprometida de um funcionário que ainda está ligada e com sessão iniciada. O respondente precisa preservar a evidência mais volátil antes de coletar o disco rígido. Qual ação o respondente deve tomar primeiro?

A) Remover o cabo de energia para impedir criptografia

B) Capturar o conteúdo da RAM usando uma ferramenta forense de aquisição de memória

C) Criar uma imagem bit a bit do disco rígido

D) Coletar fitas de backup do data center

QUESTÃO 2 · CENÁRIO DE EXAME

Durante um incidente de cibersegurança, o departamento jurídico informa à equipe de segurança que um litígio é razoavelmente previsto. Qual ação melhor atende à necessidade de preservar informações armazenadas eletronicamente?

A) Ativar a exclusão automática de logs com mais de 30 dias

B) Emitir um aviso de legal hold e suspender a destruição rotineira de dados relevantes

C) Mover todos os sistemas afetados para uma nuvem pública

D) Permitir que os usuários continuem a limpeza normal de arquivos até que uma intimação chegue

QUESTÃO 3 · CENÁRIO DE EXAME

Um examinador forense recebe uma sacola lacrada de evidências contendo um pen drive infectado por malware de um escritório remoto. O examinador assina um recibo e depois transfere o drive para um laboratório de malware. O que deve ser documentado para manter a admissibilidade?

A) A cadeia de custódia, incluindo cada pessoa que manuseou a evidência e os horários

B) A versão da assinatura antivírus usada no endpoint do escritório remoto

C) A topologia de rede do escritório remoto

D) O histórico de navegação do usuário nas últimas 24 horas

QUESTÃO 4 · CENÁRIO DE EXAME

Um investigador precisa adquirir uma imagem forense de um laptop suspeito. O laptop está desligado e o disco não foi alterado. Qual método de aquisição melhor apoia o uso posterior em tribunal?

A) Inicializar o laptop e copiar arquivos do usuário para um drive externo

B) Usar um bloqueador de escrita e uma ferramenta de imagem forense para criar uma cópia bit a bit, depois gerar hash da imagem

C) Tirar capturas de tela do explorador de arquivos e salvá-las como PDF

D) Executar a ferramenta de recuperação do sistema operacional para exportar documentos

QUESTÃO 5 · CENÁRIO DE EXAME

Após criar uma imagem forense do disco rígido de um servidor, o examinador calcula hashes SHA-256 do disco original e da imagem. Durante o julgamento, a parte adversa questiona se a imagem foi modificada. Qual é o objetivo principal desses hashes?

A) Compactar a imagem para armazenamento de longo prazo

B) Criptografar a imagem para que usuários não autorizados não possam abri-la

C) Verificar a integridade e provar que a imagem corresponde ao original

D) Identificar a família de malware no servidor

QUESTÃO 6 · CENÁRIO DE EXAME

O jurídico de uma empresa recebe um pedido de descoberta para todos os e-mails relacionados a uma alegação de fraude financeira. A equipe de segurança é solicitada a ajudar. Qual abordagem melhor se alinha aos requisitos de eDiscovery e preservação de evidências?

A) Pedir aos funcionários que excluam e-mails irrelevantes antes da coleta

B) Coletar e preservar informações armazenadas eletronicamente relevantes sob legal hold usando métodos defensáveis

C) Fornecer ao solicitante credenciais de administrador de domínio para acesso direto às caixas de correio

D) Exportar apenas a caixa de correio do CEO porque executivos são mais relevantes

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa está negociando um contrato com um provedor de serviços em nuvem. A equipe de segurança quer o direito contratual de realizar uma investigação forense se o provedor sofrer uma violação que afete dados da empresa. Qual cláusula contratual deve ser solicitada?

A) Acordo de nível de serviço (SLA)

B) Política de uso aceitável (AUP)

C) Cláusula de direito de auditoria

D) Acordo de confidencialidade (NDA)

QUESTÃO 8 · CENÁRIO DE EXAME

Um analista forense está preparando um plano de aquisição para um servidor em execução que contém transações de clientes. De acordo com a ordem de volatilidade, qual sequência o analista deve seguir?

A) Disco rígido, RAM, fitas de backup, cache da CPU

B) Fitas de backup, disco rígido, RAM, conexões de rede

C) RAM, sistemas de arquivos temporários, disco rígido, fitas de backup

D) Conexões de rede, fitas de backup, disco rígido, RAM

QUESTÃO 9 · CENÁRIO DE EXAME

A estação de trabalho de um funcionário é suspeita em um caso de roubo de dados. Um técnico coleta o laptop e o coloca no armário de evidências, mas não registra a hora da transferência nem o nome da pessoa que recebeu. Qual é a consequência mais provável?

A) O valor de hash do disco mudará automaticamente

B) A ordem de volatilidade será invertida

C) A evidência pode ser contestada como não autenticada adequadamente

D) O legal hold será convertido em um pedido de eDiscovery

QUESTÃO 10 · CENÁRIO DE EXAME

Um analista de segurança é solicitado a investigar uma possível ameaça interna. Antes de começar, o analista descobre que a organização recebeu uma notificação de advogados externos sobre litígio previsto. O que o analista deve fazer primeiro?

A) Coordenar com o jurídico e garantir que um legal hold seja emitido antes de coletar evidências

B) Começar a imaginar o laptop imediatamente e notificar o jurídico apenas se encontrar evidências

C) Suspender o acesso do funcionário e excluir a caixa de correio do suspeito para evitar vazamento de dados

D) Aguardar uma intimação antes de preservar qualquer dado

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Capturar o conteúdo da RAM usando uma ferramenta forense de aquisição de memória

A RAM é volátil e seu conteúdo é perdido quando o sistema perde energia, portanto deve ser coletada antes de fontes menos voláteis, como disco ou backups. Remover a energia destrói evidências, e imaginar o disco primeiro ignora a ordem de volatilidade.

Questão 2: Alternativa B — Emitir um aviso de legal hold e suspender a destruição rotineira de dados relevantes

Um legal hold exige que a organização preserve evidências potencialmente relevantes quando um litígio é previsto. Suspender a destruição rotineira e notificar os custodiantes ajuda a evitar a destruição de provas e apoia o eDiscovery posterior.

Questão 3: Alternativa A — A cadeia de custódia, incluindo cada pessoa que manuseou a evidência e os horários

A cadeia de custódia documenta quem teve controle da evidência, quando e com qual finalidade. Sem um registro ininterrupto, a parte adversa pode contestar a autenticidade e a integridade da evidência em tribunal.

Questão 4: Alternativa B — Usar um bloqueador de escrita e uma ferramenta de imagem forense para criar uma cópia bit a bit, depois gerar hash da imagem

Uma imagem forense é uma cópia bit a bit da mídia de armazenamento criada com um bloqueador de escrita para impedir modificações. Gerar hash do original e da imagem ajuda a demonstrar integridade e apoia a admissibilidade.

Questão 5: Alternativa C — Verificar a integridade e provar que a imagem corresponde ao original

Hashes criptográficos são usados para verificação de integridade. Se o hash do disco original corresponder ao hash da imagem forense, o examinador pode demonstrar que a imagem não foi alterada.

Questão 6: Alternativa B — Coletar e preservar informações armazenadas eletronicamente relevantes sob legal hold usando métodos defensáveis

O eDiscovery exige identificar, preservar, coletar e processar informações armazenadas eletronicamente de forma defensável. Excluir e-mails ou fornecer credenciais amplas arriscaria destruição de provas e acesso não autorizado.

Questão 7: Alternativa C — Cláusula de direito de auditoria

Uma cláusula de direito de auditoria concede à organização a capacidade contratual de auditar ou avaliar os controles do provedor e, quando necessário, investigar incidentes de segurança. Um SLA define desempenho, uma AUP define comportamento do usuário e um NDA protege informações confidenciais.

Questão 8: Alternativa C — RAM, sistemas de arquivos temporários, disco rígido, fitas de backup

A ordem de volatilidade prioriza os dados mais voláteis primeiro. RAM e sistemas de arquivos temporários podem ser perdidos rapidamente, enquanto discos rígidos e backups são menos voláteis e podem ser coletados depois.

Questão 9: Alternativa C — A evidência pode ser contestada como não autenticada adequadamente

Lacunas na cadeia de custódia dificultam provar que a evidência não foi alterada ou manuseada incorretamente. A parte adversa pode contestar sua autenticidade, potencialmente enfraquecendo ou excluindo a evidência do tribunal.

Questão 10: Alternativa A — Coordenar com o jurídico e garantir que um legal hold seja emitido antes de coletar evidências

Quando um litígio é previsto, um legal hold deve ser emitido para preservar evidências potencialmente relevantes. A equipe forense deve coordenar com o jurídico antes da coleta para que a evidência seja preservada de forma defensável e não seja destruída.